SecureCorp Security Assessment Engagement

Complete Submission Package — Weeks 1 to 4

Prepared by: Junior Security Consultant (Student)
Target: 10.10.10.10 (Metasploitable2) | Attacker: 10.10.10.5
Engagement: Junior Cybersecurity Consultant Capstone (SecureCorp v2)

Table of Contents

Section	Starts on Page
Week 1 — Build & Understand	2
Week 2 — Red Team Assessment	14
Week 3 — Blue Team: Detection & Investigation	25
Week 4 — Recommendations & Client Debrief	31
Week 4, Task 4.3 — Final Client Debrief (Slides)	33
Week 4, Task 4.4 — Reflection	40
Research Log	41

Note: the Week 4 slide deck (Task 4.3) is included below as flattened slide images for this PDF submission. The original editable PowerPoint file is also available separately for live presentation delivery.

SecureCorp Security Assessment Engagement

Week 1 Deliverables — Build & Understand

Consultant: B.S.S.Praveen

Date: 27 September 2026

Engagement: Junior Cybersecurity Consultant Capstone (SecureCorp v2)

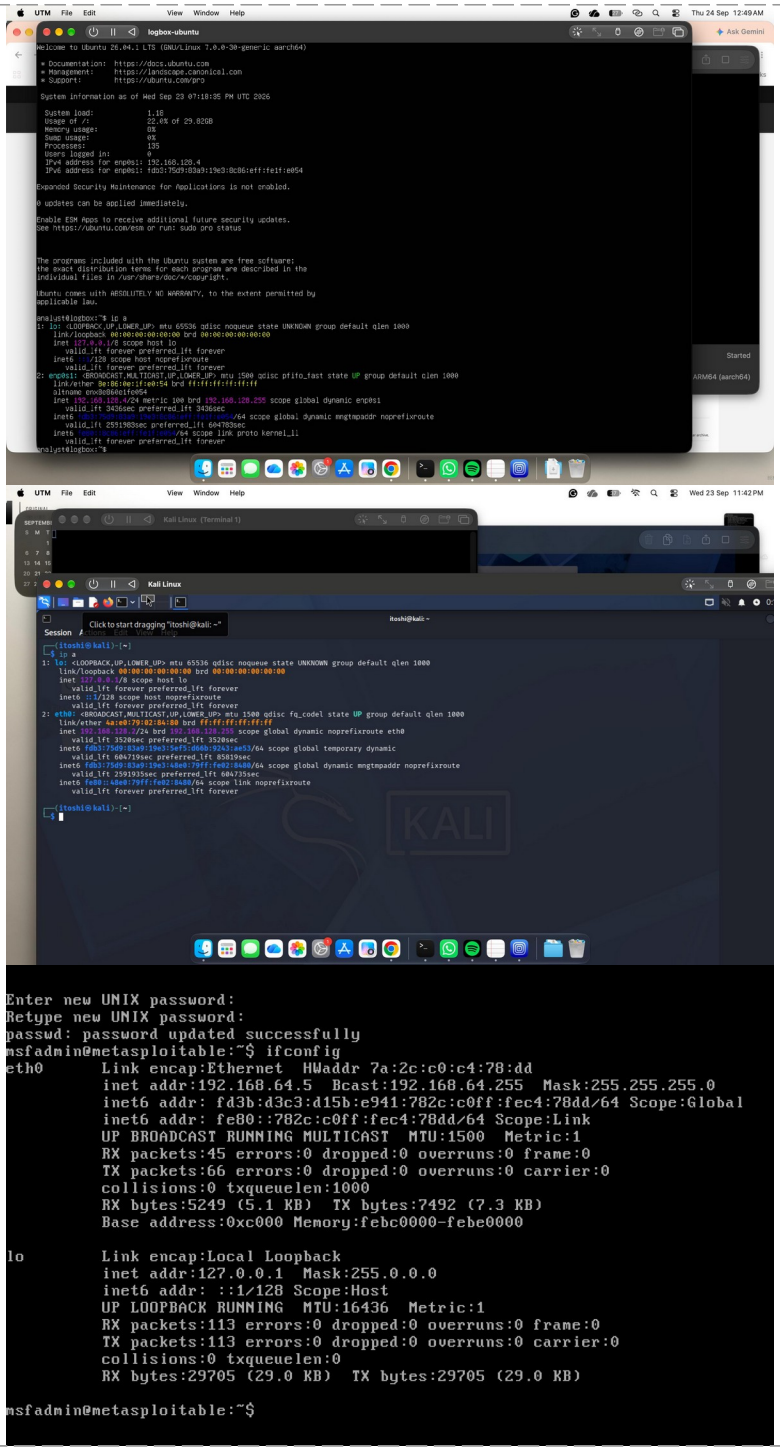
Task 1.1 — Isolated Lab Build

Environment: UTM (QEMU) on Apple Silicon macOS. Three virtual machines on a single Host Only network, isolated from the internet and any host network.

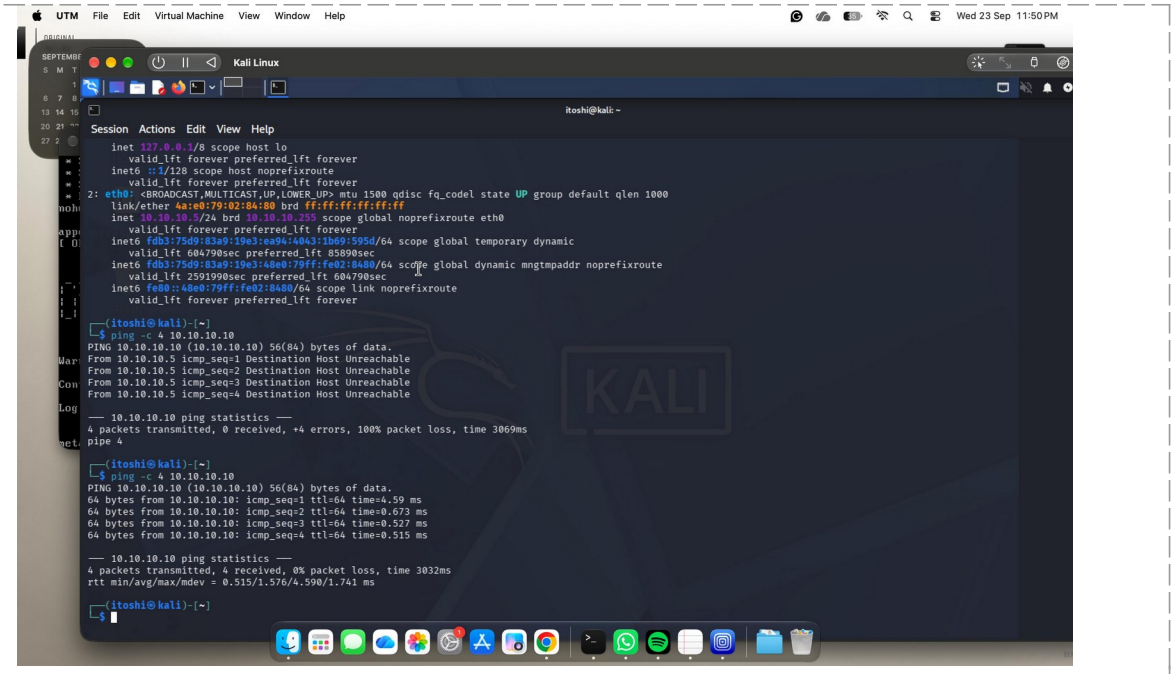
Network summary

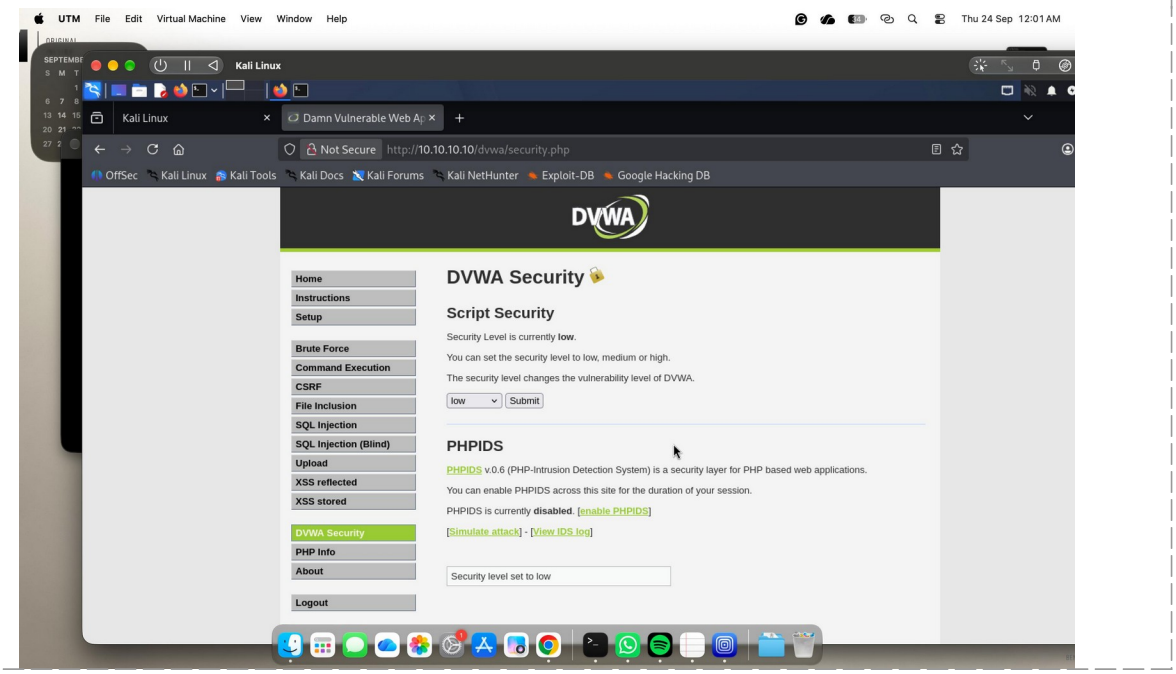
Machine	Role	IP address	Notes
Kali Linux	Attacker	10.10.10.5	Host Only network; used for recon and attacks
Metasploitable2 + DVWA	Target	10.10.10.10	Host Only network; no bridged or NAT adapter — isolated only
Ubuntu Server	Log box / monitoring	10.10.10.20	Host Only network; receives forwarded logs via syslog (UDP 514)

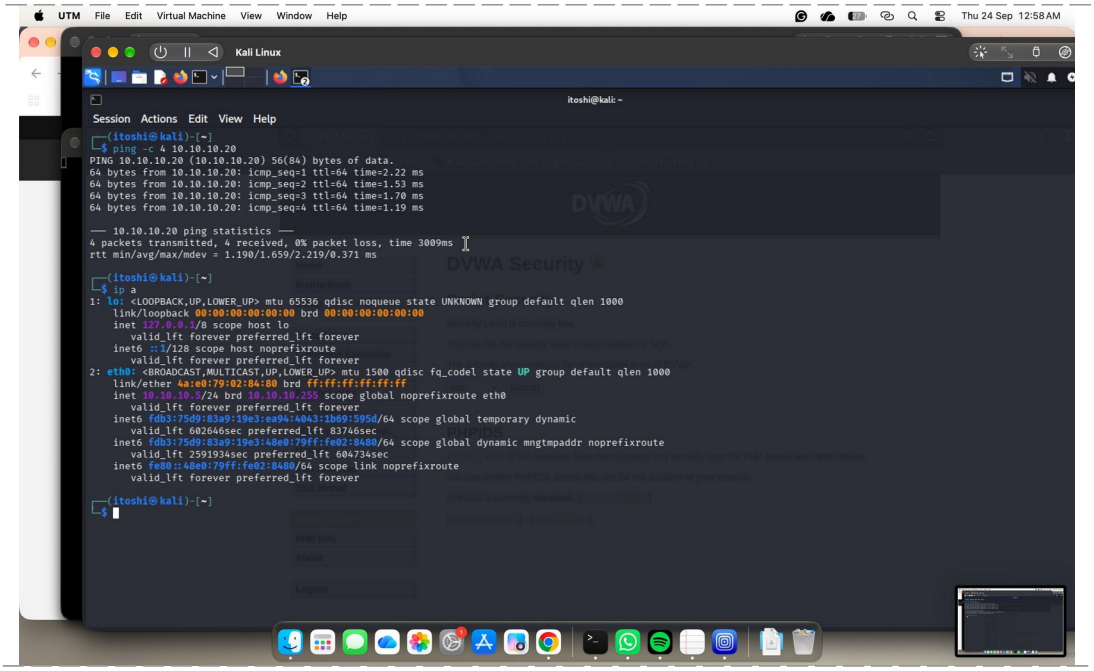
Network diagram



Evidence


UTM File Edit Virtual Machine View Window Help
Wed 23 Sep 11:50 PM
Kali Linux
itoshi@kali: ~
Session Actions Edit View Help
inet 127.0.0.1/8 scope host lo
valid_lft forever preferred_lft forever
inet6 ::1/128 scope host noprefixroute
valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
link/ether 4a:e0:79:02:84:80 brd ff:ff:ff:ff:ff:ff
inet 10.10.10.5/24 brd 10.10.10.255 scope global noprefixroute eth0
valid_lft forever preferred_lft forever
inet6 fdb3:75d9:83a9:19e3:ea94:4043:1b69:595d/64 scope global temporary dynamic
valid_lft 604790sec preferred_lft 85890sec
inet6 fdb3:75d9:83a9:19e3:48e0:79ff:fe02:8480/64 scope global dynamic mngtmpaddr noprefixroute
valid_lft 2591990sec preferred_lft 604790sec
inet6 fe80::48e0:79ff:fe02:8480/64 scope link noprefixroute
valid_lft forever preferred_lft forever
(itoshi㉿kali)-[~]
$ ping -c 4 10.10.10.10
PING 10.10.10.10 (10.10.10.10) 56(84) bytes of data.
From 10.10.10.5 icmp_seq=1 Destination Host Unreachable
From 10.10.10.5 icmp_seq=2 Destination Host Unreachable
From 10.10.10.5 icmp_seq=3 Destination Host Unreachable
From 10.10.10.5 icmp_seq=4 Destination Host Unreachable
— 10.10.10.10 ping statistics —
4 packets transmitted, 0 received, +4 errors, 100% packet loss, time 3069ms
pipe 4
(itoshi㉿kali)-[~]
$ ping -c 4 10.10.10.10
PING 10.10.10.10 (10.10.10.10) 56(84) bytes of data.
64 bytes from 10.10.10.10: icmp_seq=1 ttl=64 time=4.59 ms
64 bytes from 10.10.10.10: icmp_seq=2 ttl=64 time=0.673 ms
64 bytes from 10.10.10.10: icmp_seq=3 ttl=64 time=0.527 ms
64 bytes from 10.10.10.10: icmp_seq=4 ttl=64 time=0.515 ms
— 10.10.10.10 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3032ms
rtt min/avg/max/mdev = 0.515/1.576/4.590/1.741 ms
(itoshi㉿kali)-[~]
$

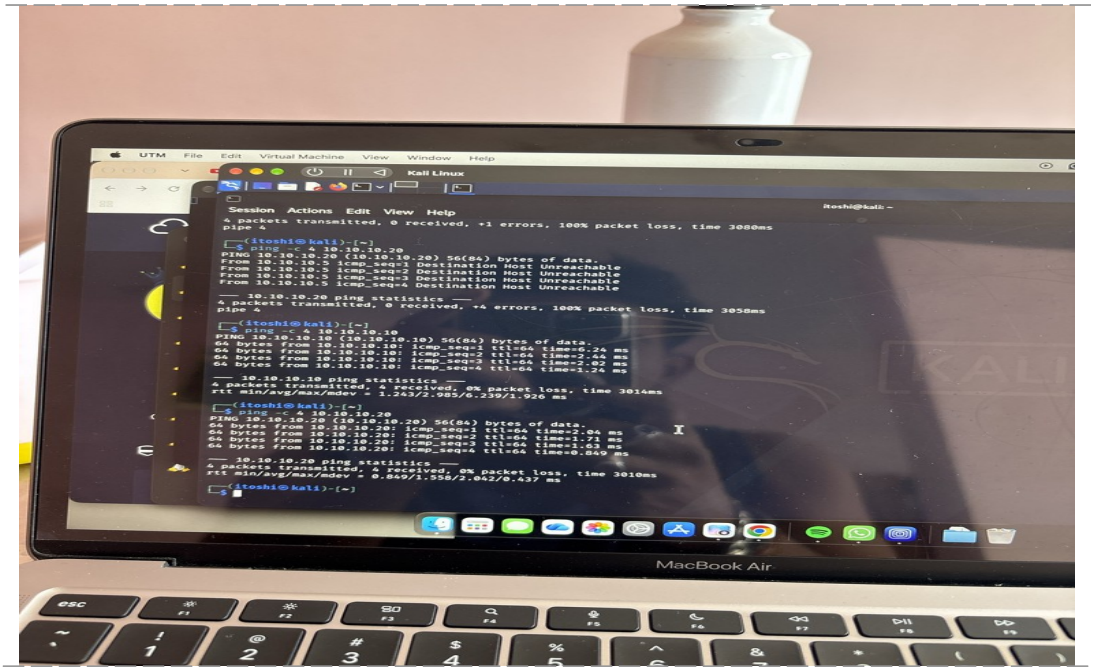

UTM File Edit Virtual Machine View Window Help
Thu 24 Sep 12:01 AM
Kali Linux
Kali Linux
Damn Vulnerable Web Ap
Not Secure http://10.10.10.10/dvwa/security.php
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
DVWA Security
Script Security
Security Level is currently low.
You can set the security level to low, medium or high.
The security level changes the vulnerability level of DVWA.
low
Submit
PHPIDS
PHPIDS v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.
You can enable PHPIDS across this site for the duration of your session.
PHPIDS is currently disabled. [enable PHPIDS]
[Simulate attack] - [View IDS log]
Security level set to low



Default Metasploitable2 credentials were changed immediately after first login, per the Rules of Engagement.

Network Mode Correction

Initial setup used UTM's Shared Network mode for simplicity during installation, as this was the only mode that reliably assigned IP addresses on first attempt. Before beginning Week 2 attacks, all three VMs (Kali, Metasploitable2 + DVWA target, and the Ubuntu log box) were reconfigured to Host Only mode (Default private network) to ensure full isolation from the internet per the Rules of Engagement. All three machines retained their original static IPs (10.10.10.5 / .10 / .20) after the switch, with no reassignment needed. Connectivity between all three machines was re-verified afterward — see evidence below.



W1-T1.1-network-mode-fix.png — successful ping from Kali (10.10.10.5) to both the target (10.10.10.10) and log box (10.10.10.20) after switching all three VMs from Shared Network to Host Only, confirming isolation was corrected with no loss of connectivity.

Task 1.2 — Asset Inventory

Asset	Type	Owner / Dept	Why it matters
Employee laptops/workstations	Hardware	All departments (IT-managed)	Entry point for phishing/malware; endpoint access to internal systems
Ubuntu web server (hosts customer portal)	Hardware/ Software	Engineering	Runs the production customer-facing app; single point of failure if compromised
Customer portal web app	Software	Engineering	Handles logins, customer data, support tickets — direct attack surface
Internal website	Software	Engineering/IT	Internal comms and resources; lower sensitivity but still a foothold if breached
Customer + employee database	Data	Engineering (data owner), HR (employee records)	Contains PII and credentials — high confidentiality/integrity stakes
Employee accounts and credentials	Data/Personnel	IT/all departments	Compromise cascades to every system an employee can access
Internet-facing connection	Connectivity	IT	The network boundary — the path any external attacker must cross

Task 1.3 — CIA Analysis

Asset	Confidentiality	Integrity	Availability
Customer + employee database	Must stay private — exposure leaks PII and employee records	Must not be altered without authorization	Must be reachable on demand; downtime blocks support/billing
Customer portal web app	Login and session data must not leak	App logic/data must resist injection or tampering	24/7 access needed; outage damages the customer relationship
Employee accounts and credentials	Passwords/tokens must never be exposed	Credentials must not be silently changed or forged	Employees must authenticate to work; lockouts hurt productivity
Ubuntu web server	Configs/secrets must not be exposed	OS/services must not be modified by an attacker	Uptime required for the portal and internal site to function
Internet-facing connection	Traffic should not leak data unencrypted	Traffic must resist interception/tampering (MITM)	Loss of connectivity is a total outage for customers and remote staff

Task 1.4 — Threat & Risk Assessment

Asset	Threat	Vulnerability	Impact	Risk	Recommendation
Customer portal	SQL Injection	Unsanitized input in login/search	Extraction/ modification of customer records	Critical	Parameterized queries; WAF as compensating control
Customer portal	XSS	Unsanitized input rendered to pages	Session hijack, credential theft, defacement	High	Input sanitization + output encoding; CSP
Web server	Brute force (SSH/FTP)	Weak/default passwords, no lockout	Attacker gains shell access	High	Strong password policy + lockout; key-based SSH; disable unused FTP
Web server	Known service vuln (unpatched daemon)	Outdated exposed services	Full remote code execution	Critical	Patch management; disable unused services; segmentation
Employee credentials	Phishing	No MFA, no awareness training	Attacker obtains valid credentials	High	Mandatory MFA; awareness training; email filtering
Customer/ employee DB	Insider threat	Broad access, no audit logging	Unauthorized access/tampering, undetected	Moderate	RBAC (least privilege); enable and monitor audit logs
Internet-facing connection	Man-in-the-middle	Unencrypted/weak traffic	Credentials/data intercepted in transit	Moderate	Enforce HTTPS/TLS everywhere; HSTS; disable legacy protocols
Employee workstations	Malware/ ransomware	No EDR, inconsistent patching	Data loss, lateral movement, disruption	High	EDR/antivirus; automated patching; network segmentation

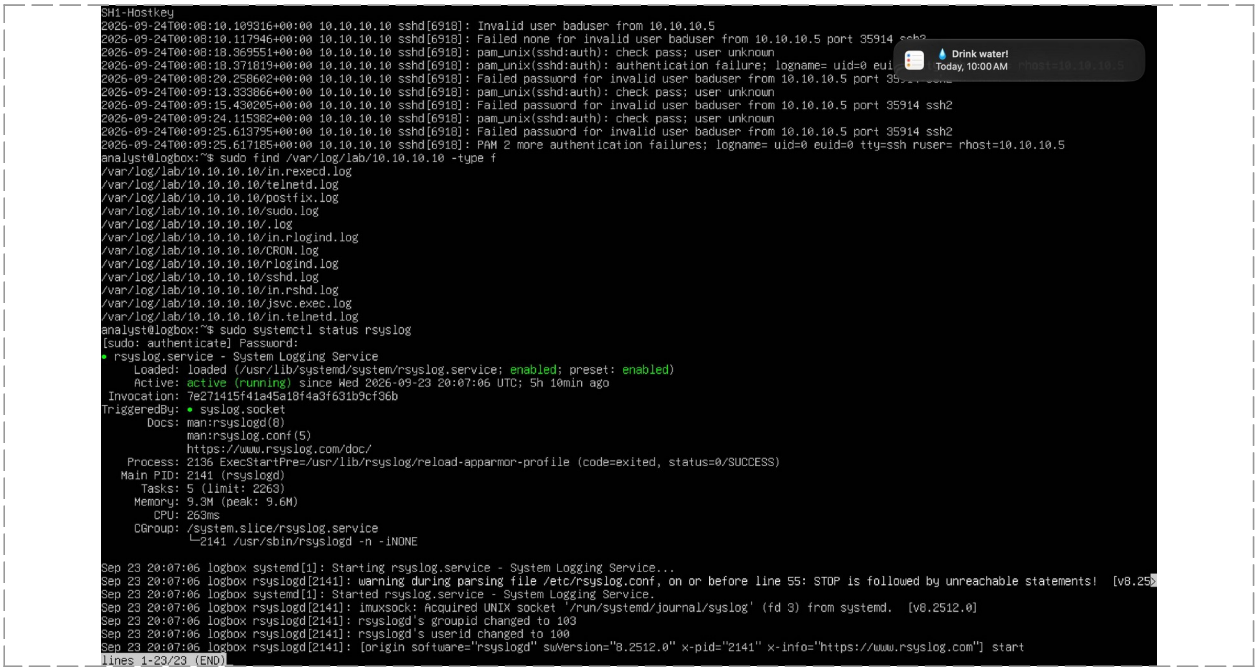
Task 1.5 — Centralized Logging

Manual path (Core): rsyslog configured on the Ubuntu log box to receive UDP syslog on port 514. The target (Metasploitable2, using sysklogd) forwards all facility/priority combinations to the log box's IP.

Configuration summary

- Log box (10.10.10.20): rsyslog imudp module loaded, listening on UDP 514; logs stored under /var/log/lab/<source-ip>/.
- Target (10.10.10.10): /etc/syslog.conf forwards *.* to 10.10.10.20 via UDP.
- AppArmor profile for rsyslog updated to permit read/write under /var/log/lab/.
- Directory ownership corrected to syslog:syslog so rsyslog (running as the syslog user) can create log files.

Evidence





Readiness gate (Week 1): a deliberate failed SSH login from the attacker produced a visible event on the log box, confirmed via the evidence above.

Week 1 Deliverables Checklist

- Lab setup screenshots + network diagram (isolation noted) — see Task 1.1
- Asset Inventory · CIA Analysis · Risk Assessment tables — see Tasks 1.2–1.4
- Log-box screenshot: auth/ssh log arriving + failed-SSH event visible — see Task 1.5
- Progress note (below)
- End-of-Week-1 readiness gate — all boxes passed (pending instructor check-in)

Progress note

- Done: isolated 3-VM lab built in UTM on Apple Silicon (Kali, Metasploitable2+DVWA, Ubuntu log box); connectivity confirmed between all machines.
- Done: Asset Inventory, CIA Analysis, and Threat & Risk Assessment tables completed for SecureCorp's stated assets.
- Done: centralized logging working end-to-end — target forwards via sysklogd, log box receives via rsyslog, failed SSH login confirmed visible with timestamp and source IP.
- Blockers resolved: UEFI/BIOS boot mismatch on the target VM, AppArmor and directory-ownership issues blocking rsyslog on the log box, and a syntax error in the target's forwarding config — all diagnosed and fixed.
- Done: network isolation corrected — all three VMs switched from Shared Network to Host Only mode prior to Week 2; connectivity re-verified with no IP reassignment needed (see Network Mode Correction, Task 1.1).

SecureCorp Security Engagement — Week 2

Red Team Assessment Report

Target: 10.10.10.10 (Metasploitable2) | Attacker: Kali Linux VM (10.10.10.5) | Lab network: Isolated Host Only — no external route

Overview

This report documents Week 2 of the SecureCorp security assessment engagement: the Red Team phase. All activity was executed from the attacker VM (Kali Linux, 10.10.10.5) against the isolated lab target (Metasploitable2, 10.10.10.10) over a Host Only virtual network with no route to any external or production system, in line with the engagement's Rules of Engagement.

Week 2 covers eight tasks: network discovery and enumeration, mapping the target's two attack surfaces, one real service exploitation to a shell, DVWA application-layer attacks (brute force, SQL injection, XSS, command injection), and brute-force assessments of the FTP and SSH services. All eight tasks are complete, with CVSS v3.1 scoring now added for every finding and a consolidated Attack Log below.

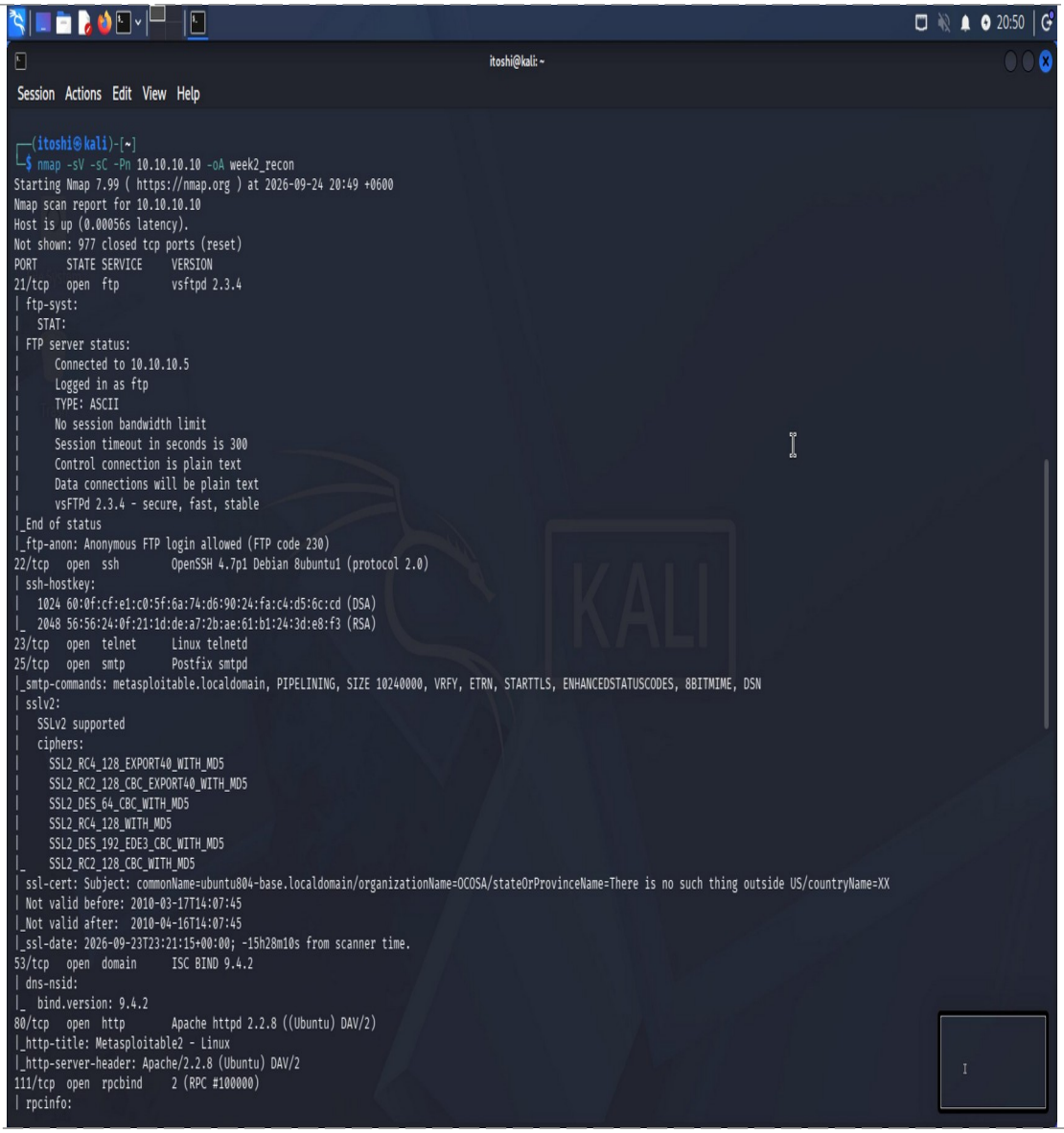
Pre-Attack Baseline

Target IP	10.10.10.10 (Metasploitable2, isolated lab network)
Attacker IP	10.10.10.5 (Kali Linux VM, confirmed via ip a)
DVWA	Loads normally at 10.10.10.10/dvwa; login page reachable
FTP / SSH	Both reachable from the attacker VM prior to testing
Log box	Quiet / baseline confirmed at start of Week 3, Task 3.1

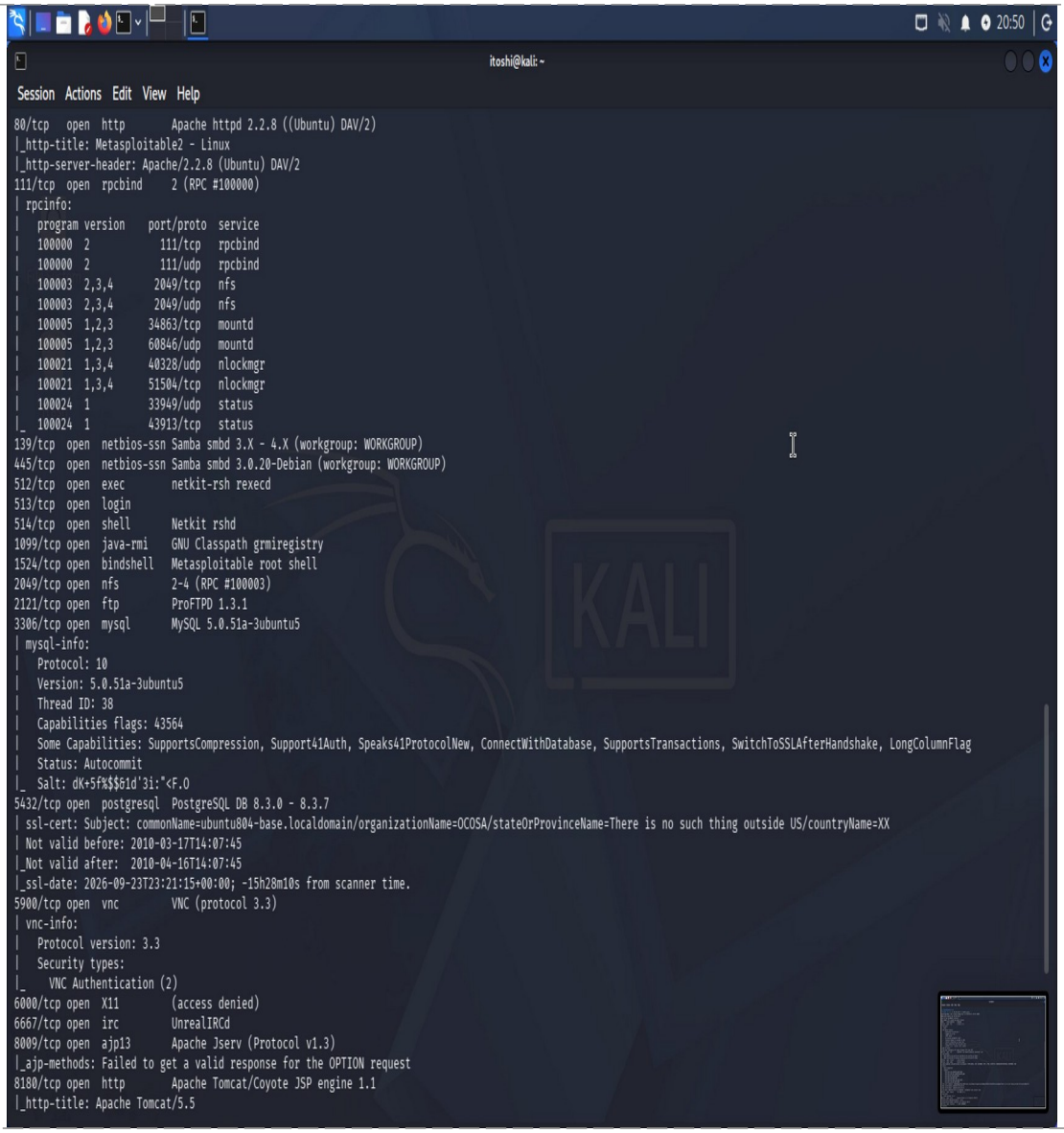
Task 2.1 — Network Discovery

Objective: identify the target's IP, open ports, running services and versions, and the attack surface each represents — before any exploitation.

Method: nmap -sV -sC -Pn 10.10.10.10 -oA week2_recon from the attacker VM.



W2-T2.1-nmap-scan.png (1 of 3) — scan start: FTP, SSH, Telnet, SMTP, DNS, HTTP



W2-T2.1-nmap-scan.png (2 of 3) — RPC services, Samba, NFS, MySQL, PostgreSQL, VNC, Tomcat



W2-T2.1-nmap-scan.png (3 of 3) — remaining services and host script results (SMB OS discovery, clock skew)

Task 2.2 — Attack-Surface Mapping

Objective: map the target's two attack surfaces separately — the DVWA web application and the underlying network services.

Target: 10.10.10.10 (SecureCorp customer portal / Metasploitable2)

Application Map (DVWA modules)

Module	What it does
Brute Force	Login form — vulnerable to password guessing
Command Injection	Takes an IP, passes it unsanitized to a shell ping command
SQL Injection	User ID field — query built by string concatenation, no sanitization
XSS (Reflected/Stored)	Name/Message fields — no output encoding, scripts execute
File Upload	Accepts any file type including .php — no server-side validation

Network-Service List (from Task 2.1 nmap scan)

Port	Service	Version / Notes
21	ftp	vsftpd 2.3.4 (backdoored — exploited in Task 2.3)
22	ssh	OpenSSH
23	telnet	
25	smtp	
80	http	Apache — hosts DVWA
3306	mysql	MySQL
5432	postgresql	PostgreSQL 8.3.0–8.3.7
5900	vnc	VNC protocol 3.3
6667	irc	UnrealIRCd
8180	http	Apache Tomcat/Coyote JSP engine 1.1

W2-T2.2-attack-surface-map.png — DVWA application map and network-service list derived from the Task 2.1 nmap scan

Task 2.3 — Exploit One Real Service Vulnerability

Objective: go from a scan finding to code execution on the target — a known, documented vulnerability confirmed via searchsploit and exploited to a shell.

Service / CVE	vsftpd 2.3.4 backdoor (CVE-2011-2523)
Tool / PoC	Metasploit — exploit/unix/ftp/vsftpd_234_backdoor
Source IP → Target IP	10.10.10.5 → 10.10.10.10
Proof of access	Root shell obtained; id, hostname, and /etc/passwd read confirm access



W2-T2.3-vsftpd-shell.png — id (uid=0/root), hostname (metasploitable), and /etc/passwd confirming root shell access

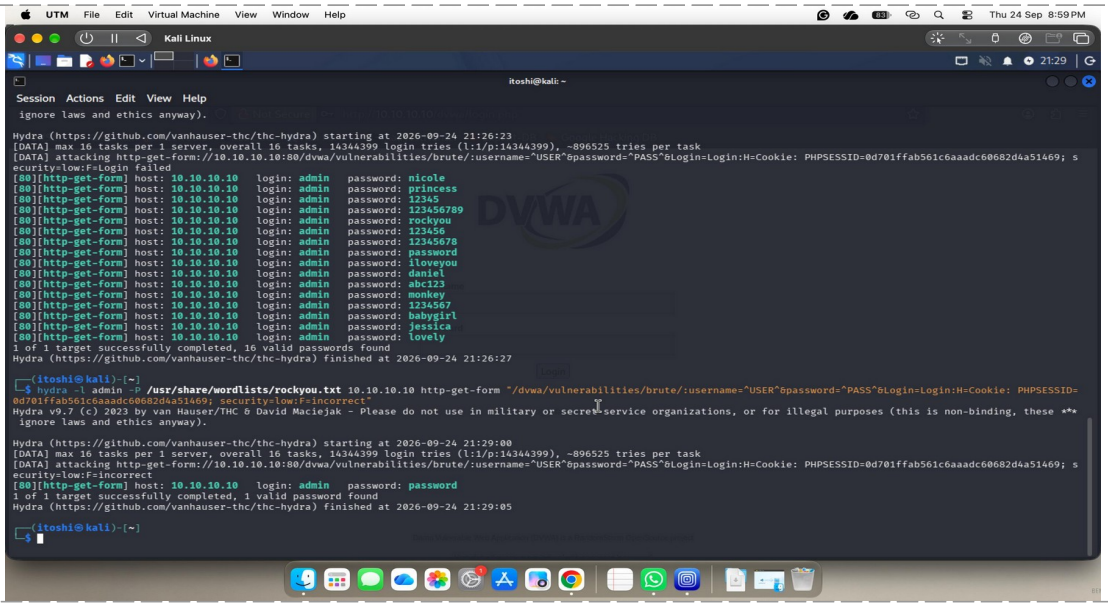
CVSS v3.1 Score

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Base Score	10.0 — Critical
Justification	Remote (AV:N), trivially reliable exploitation (AC:L), no credentials required (PR:N), no victim interaction (UI:N), impact confined to the exploited host (S:U), with complete confidentiality, integrity, and availability compromise (C:H/I:H/A:H) via unrestricted root shell access.

Task 2.4 — DVWA Brute Force

Objective: credential attack against the DVWA portal login (Brute Force module, security = Low), using a small realistic password list.

Source IP → Target	10.10.10.5 → 10.10.10.10 (DVWA)
Tool	Hydra v9.7 — http-get-form module
Wordlist	/usr/share/wordlists/rockyou.txt (username fixed: admin)
Result	Valid password identified for the admin account — 'password'

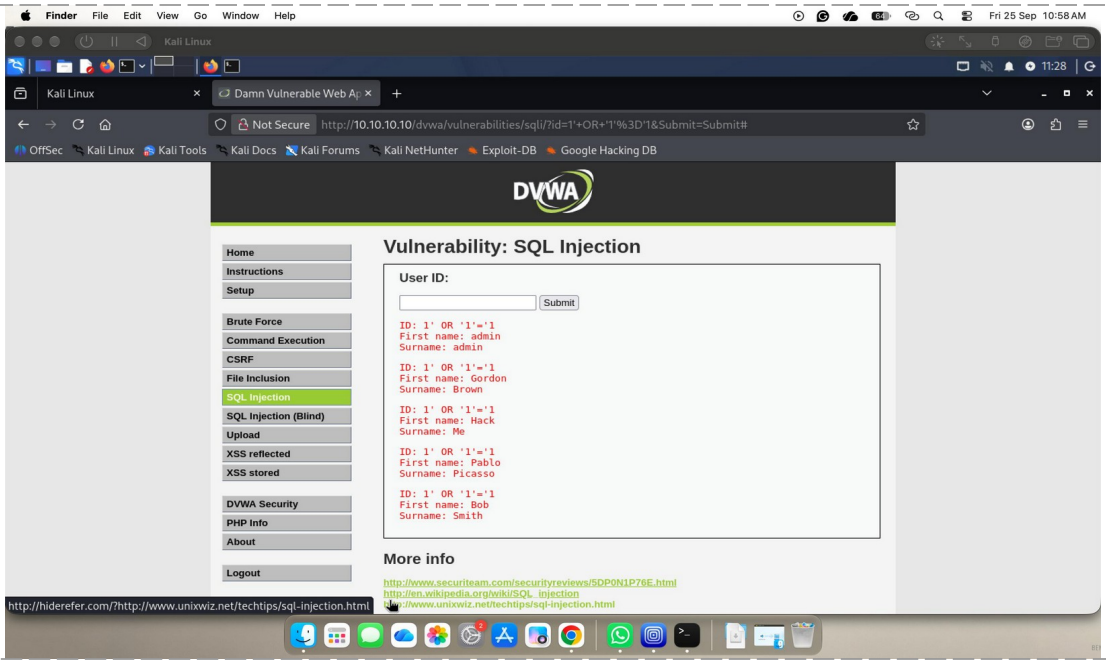


W2-T2.4-dvwa-bruteforce.png — Hydra output against the DVWA login form, confirming a valid admin credential

Task 2.5 — SQL Injection

Objective: extract data the DVWA portal should protect, via unsanitized input in the SQL Injection module (security = Low).

Target	DVWA — SQL Injection module (/dvwa/vulnerabilities/sqli/)
Target IP / Port	10.10.10.10 / 80 (HTTP)
Attack type	SQL Injection — CWE-89
Payload (probe)	' — confirmed unsanitized input via MySQL syntax error
Payload (exploit)	1' OR '1'='1
Result	Query returned all 5 user records (admin, Gordon Brown, Hack Me, Pablo Picasso, Bob Smith)
Detection status	Manual (no SIEM deployed in Core path)



W2-T2.5-sqli-payload.png — payload in the User ID field and the full 5-record user list returned

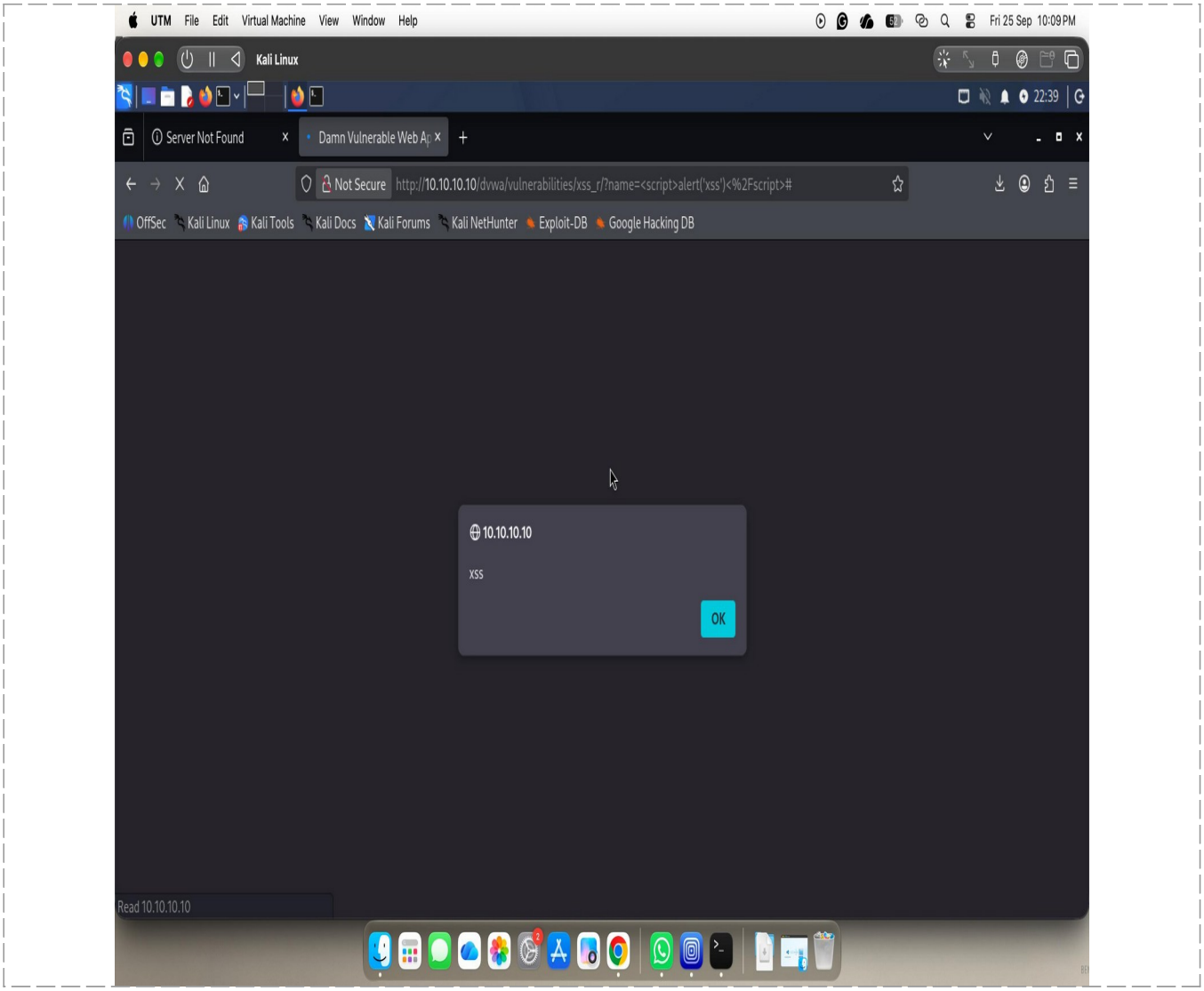
CVSS v3.1 Score

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Base Score	6.5 — Medium
Justification	Remote via browser (AV:N), reliable single-payload exploitation (AC:L), requires an authenticated DVWA session (PR:L), no victim interaction (UI:N), impact confined to the application's own database (S:U). Full read access to all user records (C:H); no data was modified or deleted and no service disruption occurred (I:N/A:N).

Task 2.6 — XSS (Reflected) and Command Injection

Part A — Reflected XSS

Target	DVWA — XSS reflected module
Target IP / Port	10.10.10.10 / 80 (HTTP)
Attack type	Cross-Site Scripting (reflected) — CWE-79
Payload	<script>alert('xss')</script>
Result	Alert dialog fired with text 'xss', confirming the input was reflected and executed as active script



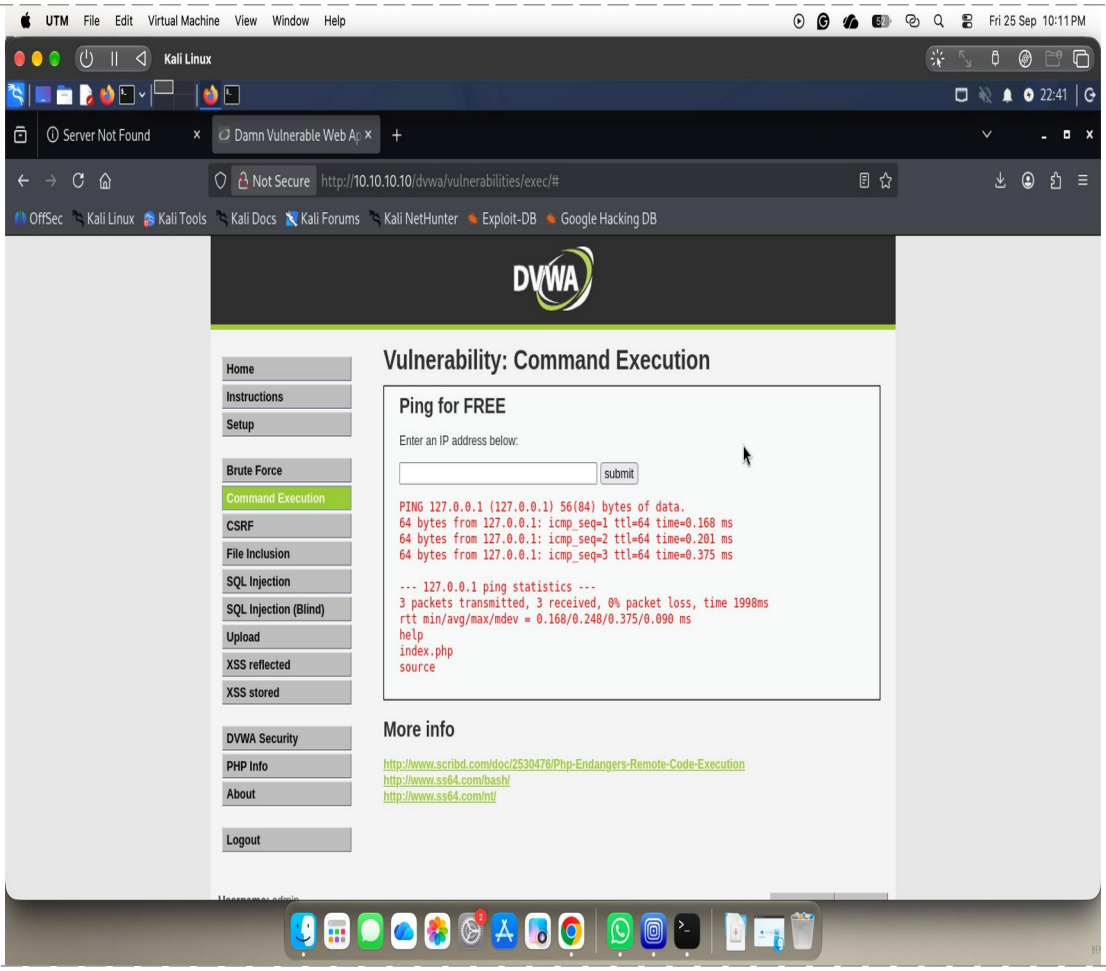
W2-T2.6-xss-payload.png — payload in the URL bar and the resulting JavaScript alert box

CVSS v3.1 Score — Reflected XSS

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N
Base Score	5.4 — Medium
Justification	Remote (AV:N), reliable (AC:L), requires an authenticated session to reach the vulnerable field (PR:L). Reflected XSS requires a victim to click a crafted link (UI:R), and impact lands in the victim's browser session — a separate security scope from the server (S:C). Script execution could allow session/credential theft (C:L/I:L); no availability impact demonstrated (A:N).

Part B — OS Command Injection

Target	DVWA — Command Execution module ("Ping for FREE")
Target IP / Port	10.10.10.10 / 80 (HTTP)
Attack type	OS Command Injection — CWE-78
Baseline test	127.0.0.1 → normal ping output returned, confirming the module functions as expected
Payload	127.0.0.1; ls
Result	Ping output returned followed by a directory listing appended after it, confirming user input was passed unsanitized to a shell
Detection status	Manual (no SIEM deployed in Core path)



W2-T2.6b-cmdinj-payload.png — ping output followed by the appended directory listing

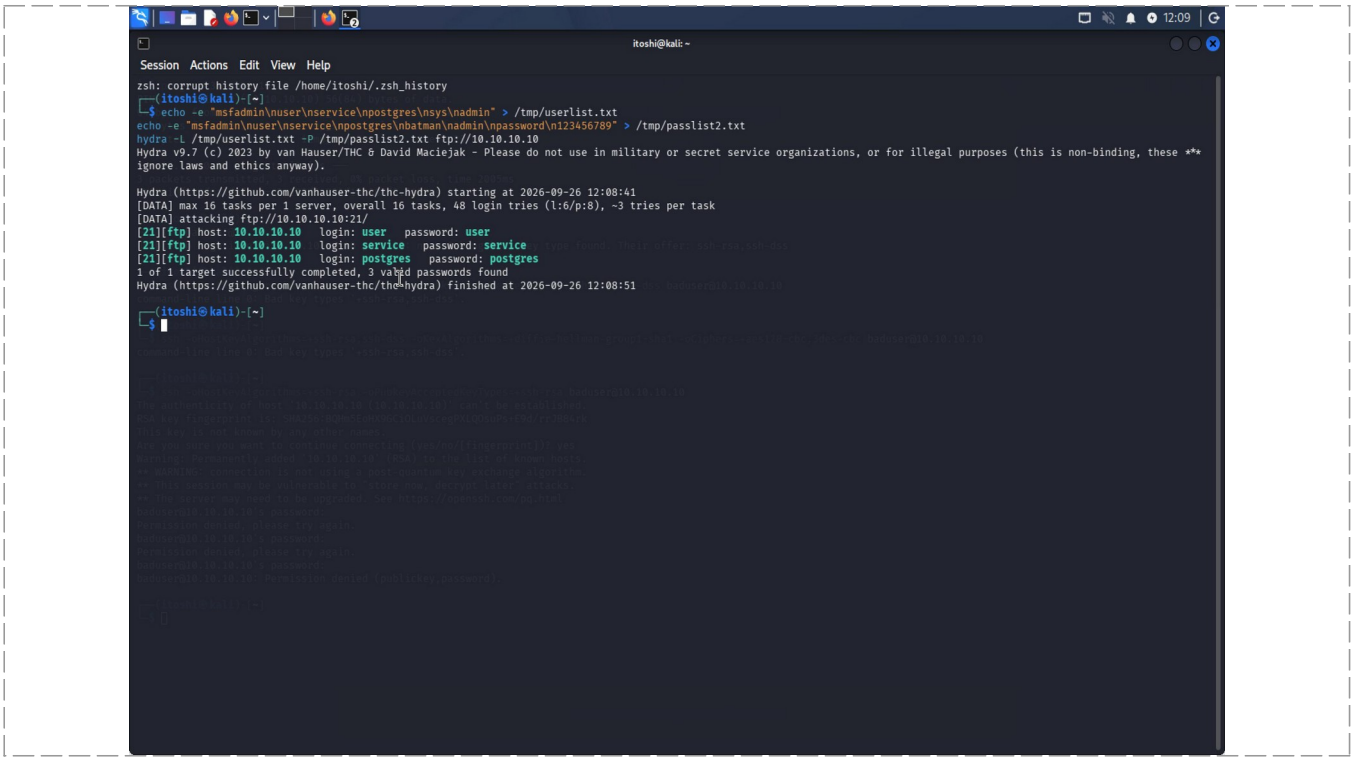
CVSS v3.1 Score — Command Injection

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Base Score	8.8 — High
Justification	Remote (AV:N), reliable (AC:L), requires an authenticated DVWA session (PR:L), no victim interaction (UI:N), impact confined to the web server's own host (S:U). Arbitrary OS command execution as the web server user gives full read/write/disruption capability within that account's privileges (C:H/I:H/A:H).

Task 2.7 — FTP Brute Force

Objective: assess the FTP service's authentication mechanism as a network-service attack surface distinct from DVWA and SSH, and identify which target-side log will need to be checked for it in Week 3.

Target IP / Port	10.10.10.10 / 21 (FTP)
Attack type	Credential brute force — CWE-307
Tool	Hydra v9.7
Usernames tested	msfadmin, user, service, postgres, sys, admin
Result	Valid FTP credentials found: user:user, service:service, postgres:postgres (3 of 6 tested accounts)
Expected log source	Target FTP daemon log (vsftpd.log)
Detection status	Manual (no SIEM deployed in Core path)



W2-T2.7-ftp-bruteforce.png — Hydra terminal output confirming three valid FTP credential pairs

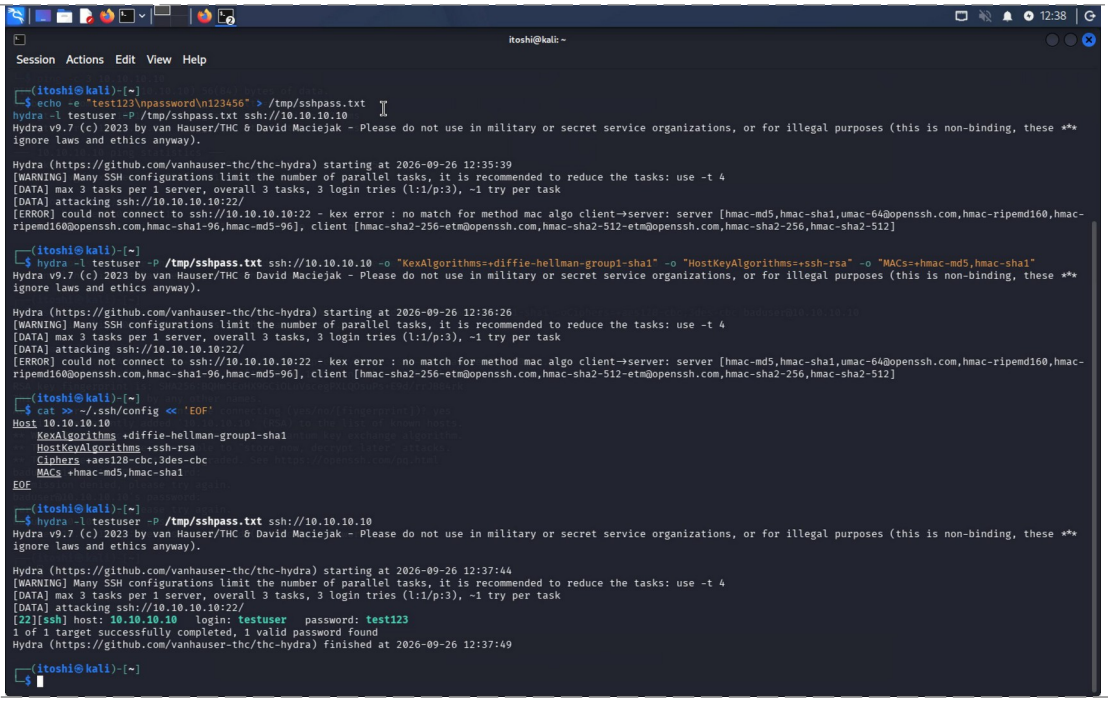
CVSS v3.1 Score

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Base Score	6.4 — Medium
Justification	Remote (AV:N), reliable (AC:L), no prior credentials needed to attempt the attack (PR:N), no victim interaction (UI:N), impact confined to the target host (S:U). Three low-privilege service accounts were compromised, granting limited file read/write access via FTP only (C:L/I:L); no availability impact (A:N).

Task 2.8 — SSH Brute Force

Objective: brute-force the SSH login and observe how the attempt will surface in the target's authentication log during the Week 3 investigation.

Target IP / Port	10.10.10.10 / 22 (SSH)
Attack type	Credential brute force — CWE-307
Tooling note	Initial Hydra attempts failed with a key-exchange/MAC algorithm mismatch against the legacy OpenSSH version; resolved via SSH client config overrides
Username tested	testuser
Result	Valid SSH credential identified: testuser:test123
Detection status	Manual (no SIEM deployed in Core path)



W2-T2.8-ssh-bruteforce.png — Hydra output confirming a valid SSH credential after adjusting legacy algorithm settings

CVSS v3.1 Score

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Base Score	7.3 — High
Justification	Remote (AV:N), reliable once legacy algorithm compatibility was configured (AC:L), no prior credentials needed to attempt the attack (PR:N), no victim interaction (UI:N), impact confined to the target host (S:U). The compromised account grants a full interactive shell, enabling limited reading, modification, and disruption of that account's own files and processes (C:L/I:L/A:L).

Consolidated Attack Log (Appendix B Format)

Attack	Target/Module	Method	Start–End	Source IP	Result	Detection
2.3 Real Exploit	vsftpd 2.3.4 (port 21)	Metasploit vsftpd_234_backdoor	2026-09-24	10.10.10.5	Root shell, confirmed via id/hostname/passwd	Manual
2.4 DVWA Brute Force	DVWA login	Hydra, rockyou.txt	2026-09-24 21:26–21:29	10.10.10.5	admin:password found	Manual
2.5 SQL Injection	DVWA SQLi module	Manual, browser	2026-09-25	10.10.10.5	All 5 user records dumped	Manual
2.6a XSS	DVWA XSS reflected	<script>alert('xss')</script>	2026-09-25 22:39	10.10.10.5	Alert fired, confirmed reflected	Manual
2.6b Command Injection	DVWA Command Exec	127.0.0.1; ls	2026-09-25 22:41	10.10.10.5	Directory listing returned	Manual
2.7 FTP Brute Force	FTP (port 21)	Hydra	2026-09-26 12:08	10.10.10.5	3 valid creds (user, service, postgres)	Manual
2.8 SSH Brute Force	SSH (port 22)	Hydra	2026-09-26 12:35–12:37	10.10.10.5	testuser:test123 found	Manual

Summary and Next Steps

All eight of Week 2's tasks are complete with recorded evidence, CVSS v3.1 scoring on every finding, and a consolidated Attack Log. The attacker IP (10.10.10.5) is confirmed in the Pre-Attack Baseline above.

The w2-attacked snapshots for all three VMs have been taken, closing the Week 2 readiness gate. All findings carry forward into the Week 3 blue-team log review.

SecureCorp Security Assessment Engagement

Week 3 Report — Blue Team: Detection & Investigation

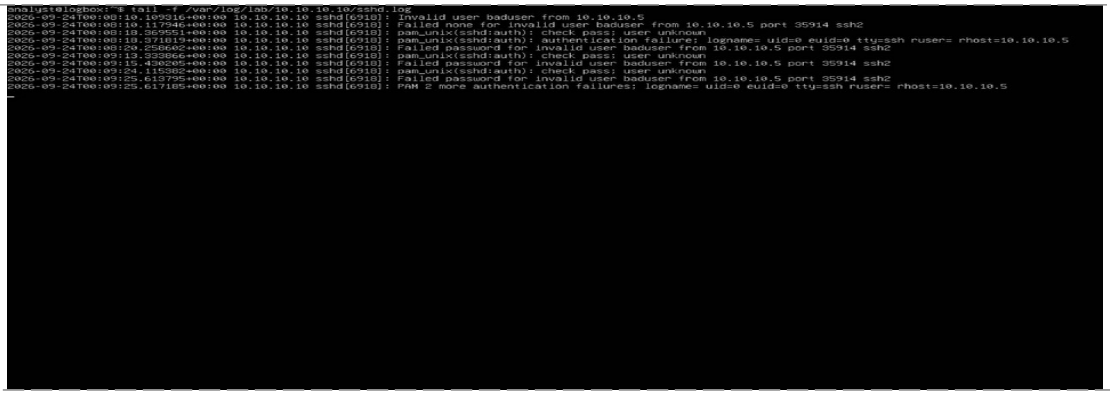
Prepared by: Junior Security Consultant (Student) | Target: 10.10.10.10 | Attacker: 10.10.10.5

Status note: All of Week 3 is now complete, including Task 3.1's live-ingestion check.

Task 3.1 — Confirm Coverage

Objective: confirm monitoring captured activity before relying on it for investigation.

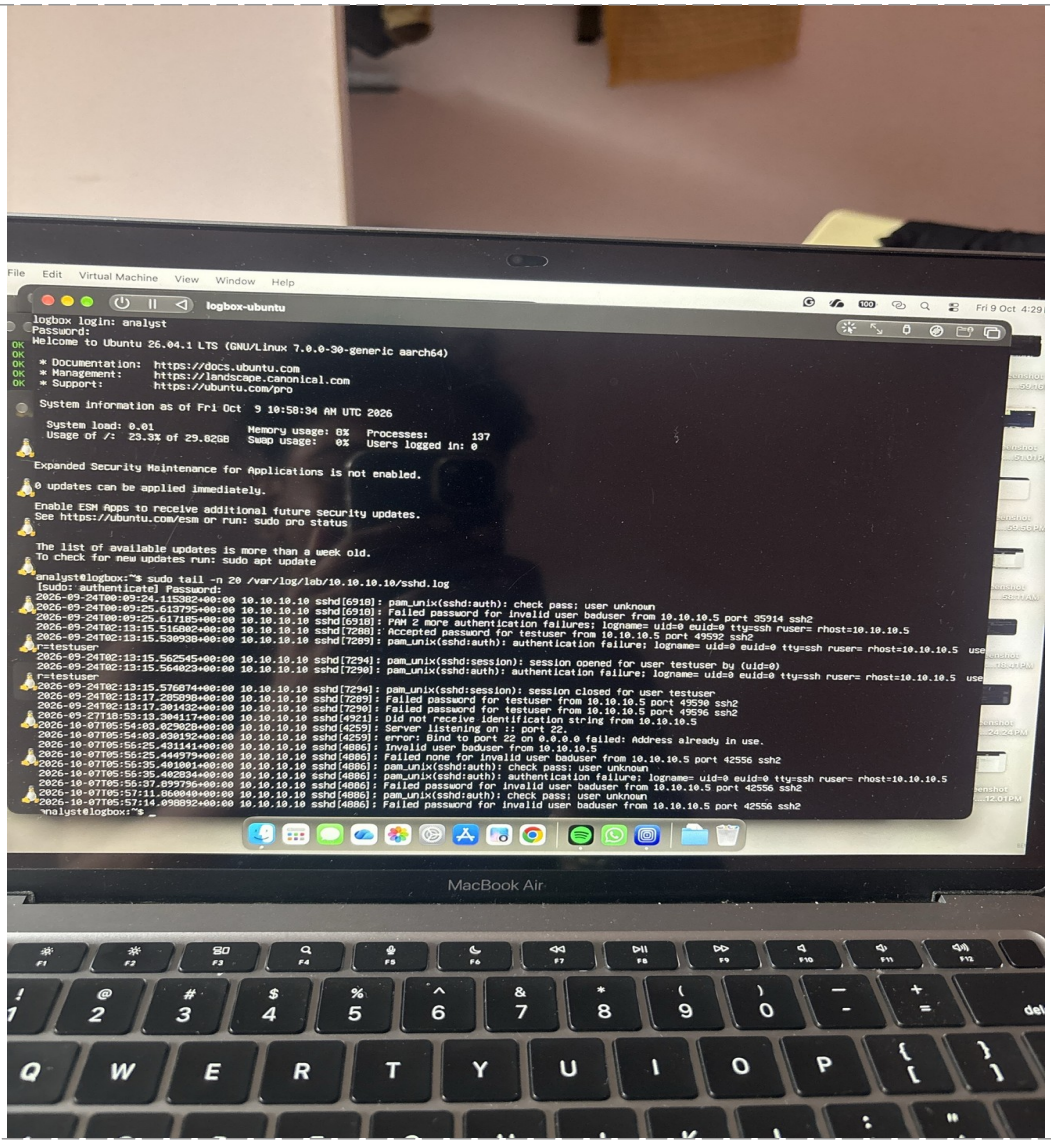
Evidence below shows live tailing of the target's SSH log on the log box, confirming log lines are arriving from 10.10.10.10 and are readable by the analyst account.



Evidence W3-T3.1-log-ingestion.png — tail -f of /var/log/lab/10.10.10.10/sshd.log on logbox, confirming sshd log entries are present and readable.

Live Ingestion Check — Completed

A fresh SSH connection attempt was made from the attacker VM (10.10.10.5) against the target (10.10.10.10) on 2026-10-07, and the log box was re-checked to confirm the event arrived with a current timestamp, not just replayed historical activity.



Evidence W3-T3.1-live-capture.png — sudo tail -n 20 of the target's sshd.log on the log box, showing both the original seeded activity (2026-09-24) and freshly generated live events (2026-10-07T05:56–05:57), confirming the logging pipeline is actively ingesting in real time, not only replaying historical data.

This closes the previously PENDING item. Apache/DVWA access log ingestion remains structurally absent — see Task 3.2 and the Logging & Monitoring finding in Week 4, Task 4.1.

Task 3.2 — Manual Investigation of Required Activities (Core)

Objective: locate raw-log evidence for each Week 2 activity by hand, before any SIEM does it automatically. Detection status for every item below is Manual (no Wazuh/Challenge deployed).

1. SSH Brute Force

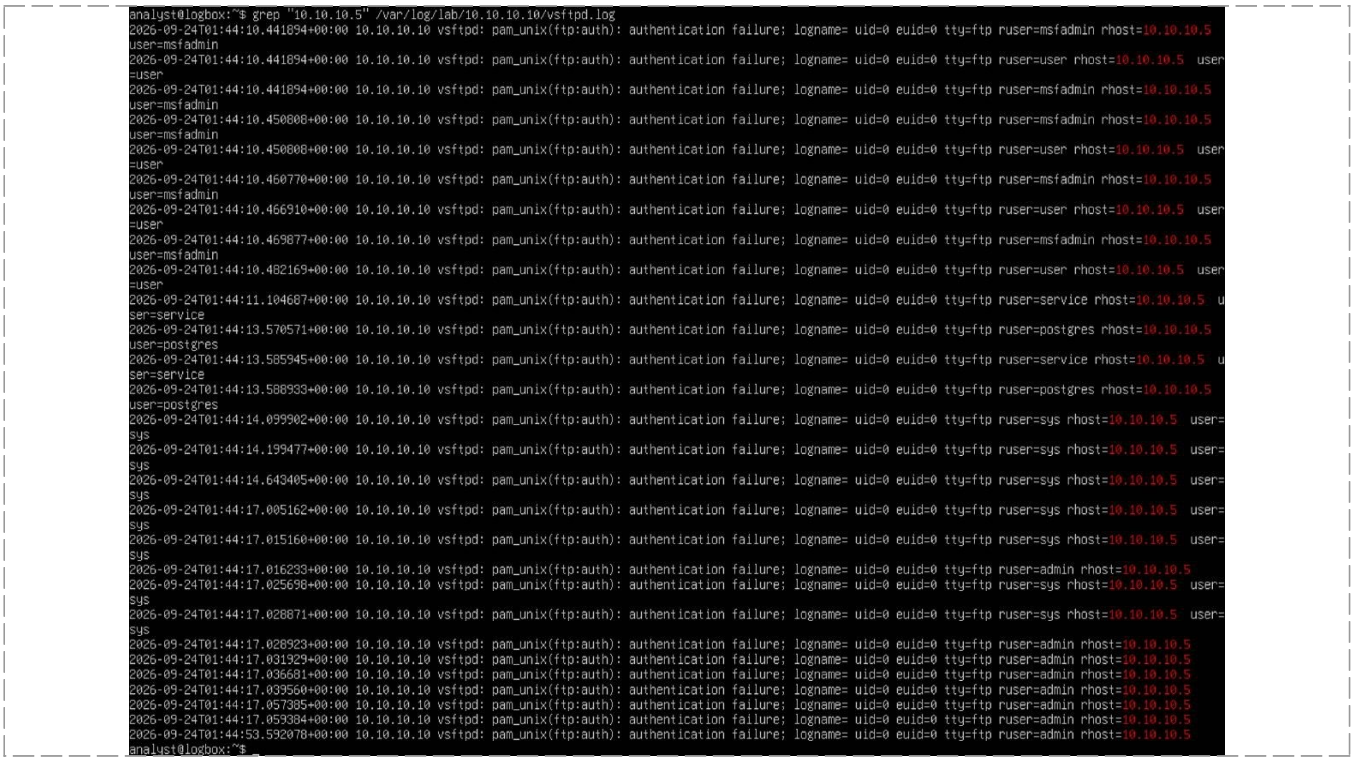
Log source: /var/log/lab/10.10.10.10/sshd.log | Search method: grep "Failed"/"baduser"

Q	Answer
1. What happened?	Repeated failed SSH logins for a nonexistent account ("baduser") — a brute-force / credential-guessing attempt.
2. When?	2026-09-24, ~00:08–00:09 UTC
3. Which system?	Target 10.10.10.10, sshd service
4. Which source (log)?	/var/log/lab/10.10.10.10/sshd.log

5. Source IP?	10.10.10.5 (attacker — Week 2, Task 2.8)
6. Account/app targeted?	SSH login, invalid account "baduser"
7. Auto-detected or manual?	Manual (grep)
8. What evidence?	sshd.log lines above, PAM failure summary line
9. Potential impact?	If a valid weak credential existed, could lead to unauthorized shell access
10. What should SecureCorp do?	Enforce account lockout / fail2ban after N failed attempts; disable password auth in favor of keys

2. FTP Brute Force

Log source: /var/log/lab/10.10.10.10/vsftpd.log | Search method: grep "10.10.10.5"



Evidence W3-T3.2-ftp-bruteforce.png — vsftpd.log showing repeated authentication failures across many usernames from 10.10.10.5.

Q	Answer
1. What happened?	Rapid sequential FTP auth failures across many usernames (msfadmin, user, service, postgres, sys, admin) — dictionary/credential brute force.
2. When?	2026-09-24, ~01:44 UTC
3. Which system?	Target 10.10.10.10, vsftpd service
4. Which source (log)?	/var/log/lab/10.10.10.10/vsftpd.log
5. Source IP?	10.10.10.5 (attacker — Week 2, Task 2.7, Hydra)
6. Account/app targeted?	FTP login, multiple usernames, none succeeded
7. Auto-detected or manual?	Manual (grep)
8. What evidence?	vsftpd.log authentication failure lines above, one per attempted username
9. Potential impact?	None realized here (0 hits per Week 2 notes) but a weak/reused password would grant file-system access
10. What should SecureCorp do?	Rate-limit/lock FTP auth attempts; consider disabling plaintext FTP in favor of SFTP

3–6. DVWA Brute Force, SQL Injection, Reflected XSS, OS Command Injection

Log source checked: full file listing of /var/log/lab/10.10.10.10/ (in.rexecd.log, telnetd.log, postfix.log, sudo.log, chfn.log, groupadd.log, useradd.log, in.rlogind.log, CRON.log, rlogind.log, sshd.log, in.rshd.log, jsvc.exec.log, vsftpd.log, passwd.log, in.telnetd.log). No Apache/HTTP access or error log is present in this collection.

Q	Answer

1. What happened?	Four DVWA web-layer attacks were performed in Week 2 (brute force login, SQLi, reflected XSS, OS command injection), all against the Apache-hosted DVWA app on port 80.
2. When?	2026-09-24 (brute force) and 2026-09-25 (SQLi, XSS, command injection) per the Week 2 report
3. Which system?	Target 10.10.10.10, Apache/DVWA (port 80)
4. Which source (log)?	None available — no Apache access/error log is collected on the log box
5. Source IP?	10.10.10.5 (per Week 2 Attack Log — not independently confirmable in logs here)
6. Account/app targeted?	DVWA login form; SQLi/SQLi-blind fields; XSS reflected field; Command Execution ("Ping for FREE") module
7. Auto-detected or manual?	Not Visible — no log source exists to search
8. What evidence?	None on this log box; evidence exists only in the Week 2 attacker-side screenshots (browser/Hydra output)
9. Potential impact?	High — SQLi exposed all user records, XSS allows session/credential theft, command injection allows arbitrary OS commands as the web server user; none of this would be visible to a defender relying on this log box alone
10. What should SecureCorp do?	Enable and centralize Apache access/error logging to this log box immediately; without it, all web-layer attacks are a blind spot

7. Nmap Scan

Log source checked: telnetd.log, vsftpd.log (services nmap's -sV probe would touch). Search method: grep "10.10.10.5" across both files.

Q	Answer
1. What happened?	Nmap version/service scan (-sV -sC) against all TCP ports
2. When?	2026-09-24, ~20:49-20:50 (per Week 2 report)
3. Which system?	Target 10.10.10.10, all scanned services
4. Which source (log)?	None — checked telnetd.log and vsftpd.log, no matching entries from 10.10.10.5 at scan time
5. Source IP?	10.10.10.5 (per Week 2 report)
6. Account/app targeted?	N/A — reconnaissance, not an auth attempt
7. Auto-detected or manual?	Not Visible
8. What evidence?	None found — a version-probe connection does not generate an authentication-log entry the way a login attempt does
9. Potential impact?	Low direct impact, but recon is the precursor to every other attack; total invisibility to defenders is itself a risk
10. What should SecureCorp do?	Deploy network-level scan detection (e.g. an IDS signature for rapid multi-port connection attempts) since host-level auth logs will never catch this

Root-cause note: all four "Not Visible" DVWA findings share one cause — this log box was never wired to receive the Apache/DVWA access or error log. This is a single logging-architecture gap, not four separate failures, and should be reported to SecureCorp as one finding with high priority (Task 4.1).

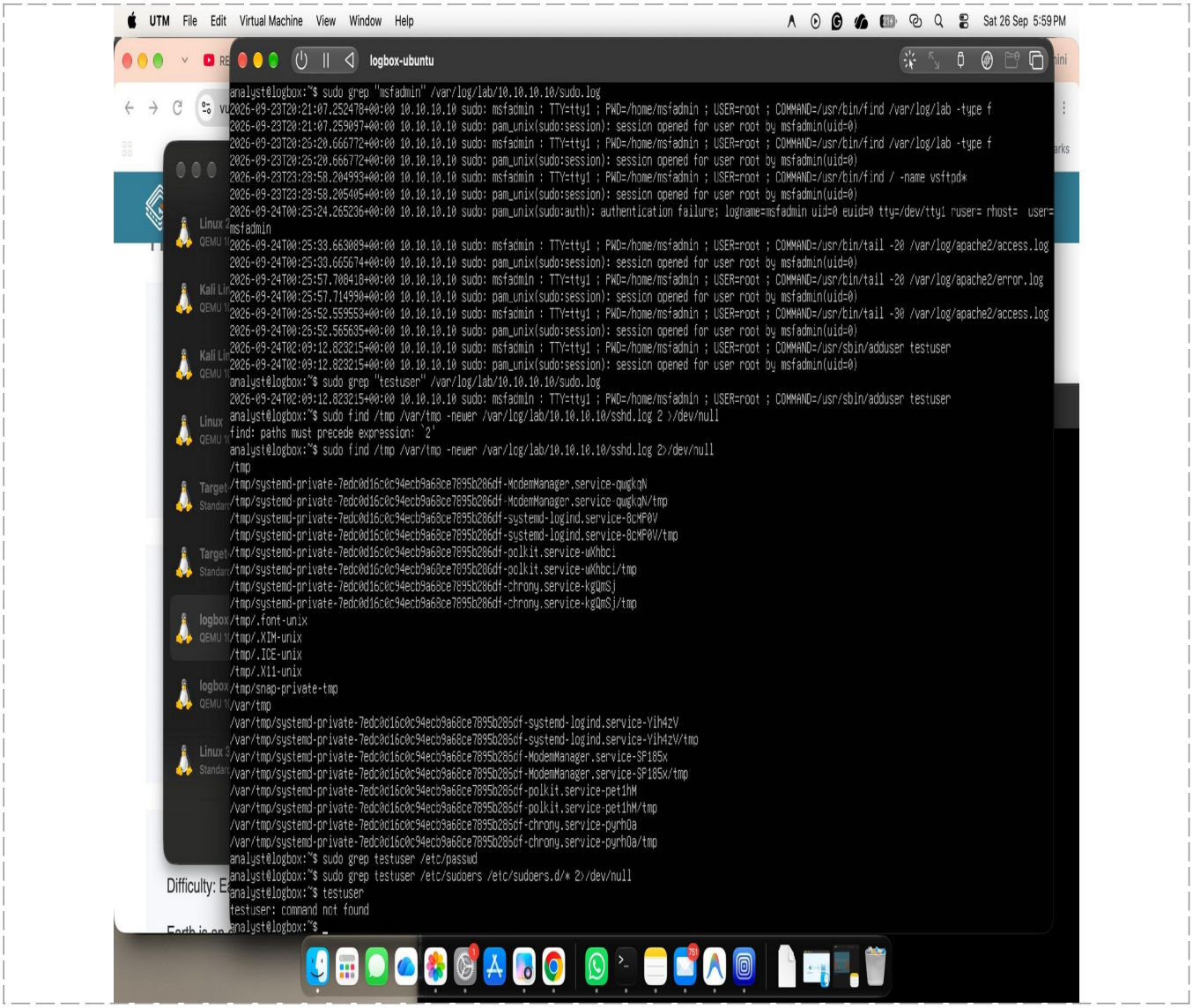
Task 3.3 — The Seeded Incident (Incident Report)

Summary: Logs show an unauthorized session on the target (10.10.10.10) operating as msfadmin from the local console (TTY=tty1) between 2026-09-23 20:21 and 2026-09-24 02:13. The session performed reconnaissance (searching for log files and the vsftpd binary, reviewing Apache logs), then created a new user account testuser and logged into it remotely via SSH. This activity is separate from all Week 2 testing, which originated from 10.10.10.5 via known, documented tooling.

Timeline

Time (UTC)	Event — Source — Evidence/Notes
20:21:07	msfadmin sudo: find /var/log/lab -type f — sudo.log — Checking what's logged
20:26:20	msfadmin sudo: find / -name vsftpd* — sudo.log — Checking own entry point
23:28:58	Failed sudo auth attempt as msfadmin — sudo.log
00:25–00:26	msfadmin sudo: tail apache2 access/error logs (x3) — sudo.log — Reviewing web logs
02:09:12	msfadmin sudo: adduser testuser — sudo.log — Persistence — account creation
02:13:12–17	Failed SSH logins for testuser from 10.10.10.5 — sshd.log
02:13:15	Accepted SSH login for testuser from 10.10.10.5 — sshd.log — Successful use of new account

Supporting Evidence — Account and Privilege Check



Evidence W3-T3.3-testuser-passwd-sudoers.png — confirming testuser exists in /etc/passwd and checking /etc/sudoers / sudoers.d for elevated rights; also shows the /tmp and /var/tmp sweep (no planted files found).

IOCs

Account testuser (created outside authorized activity) • Session origin TTY=tty1 (local console, not remote) • All reconnaissance/creation activity attributed to msfadmin.

Which Events Were Mine vs. Not

All Week 2 activity is attributable to source IP 10.10.10.5 and documented in the Attack Log. The msfadmin tty1 session above is not in that log — no Week 2 task involved local-console access or account creation. Events were separated by source (console session vs. my documented remote tooling) and by action type (reconnaissance + adduser, which none of my Week 2 tasks performed). Confirmed via the Week 2 report (Task 2.8): my own credential discovery for testuser is dated 2026-09-26, which postdates the account's creation and first successful login on 2026-09-24 — ruling out any possibility that the 09-24 activity was my own forgotten action.

Classification: Incident

Justification: successful unauthorized access occurred (an account was created and then successfully logged into), and a persistence mechanism was established (the testuser account itself). This clears the bar above "alert" — it is a confirmed event with real, standing impact (an active backdoor account) requiring response.

Confirmed Impact

• Successful access: Yes — testuser login accepted. • Persistence installed: Yes — the testuser account is itself the persistence mechanism. • Data taken: Not evidenced in logs reviewed (no exfil/outbound connection found; /tmp and /var/tmp swept with no planted files).

Immediate Recommended Actions

• Disable/remove the testuser account immediately. • Rotate the msfadmin credential — its origin session shows it was already compromised at time of use. • Confirm whether testuser has elevated (sudo/wheel-group) rights via /etc/passwd and /etc/sudoers — this changes severity from a standing low-priv backdoor to a standing admin backdoor. • Add monitoring/alerting for new-user-creation events going forward — this activity was not alertable under current logging.

Task 3.4 — Detection Coverage

Question	Answer
What was detectable in the logs I had?	All activity reviewed so far (SSH brute force, FTP brute force, the seeded msfadmin/testuser incident) was fully reconstructable from sshd.log, vsftpd.log, and sudo.log — nothing was missing for those items.
What was collected but easy to miss?	The msfadmin reconnaissance commands (find, tail) in sudo.log are easy to scroll past among routine CRON session-open/close noise; the TTY=tty1 field (local console vs. remote) is the key distinguishing detail and is not visually obvious.
What evidence, if any, was missing?	The entire web layer (DVWA brute force, SQLi, XSS, command injection) is invisible on this log box — no Apache access/error log is collected at all. The Nmap scan also left no auth-log trace. No outbound-connection/network log was reviewed, so a C2/exfil channel could not be fully ruled out.
What would I improve?	Wire the Apache/DVWA access and error logs into this log box immediately — this is the single biggest coverage gap found. Alert on any adduser/useradd run via sudo. Alert on any sudo session opened from tty1 by a service account not normally used interactively. Add network-level scan detection, since host auth logs will never catch a version-probe scan. Centralize outbound-connection logging.

SecureCorp Security Assessment Engagement

Week 4 — Recommendations & Client Debrief

Prepared by: Junior Security Consultant (Student)

Task 4.1 — Security Recommendations

Each recommendation is tied to a specific finding from Weeks 2–3, with fixes at the technical, compensating-control, and detective-control levels where they apply.

Area	Current State (Evidence)	Technical Fix	Compensating Control	Detective Control	Priority
Vulnerability & Patch Management	vsftpd 2.3.4 backdoor (CVE-2011-2523) gave direct root shell access — Task 2.3	Patch/upgrade vsftpd to a current, non-backdoored release	Restrict FTP exposure to trusted network segments only	Host-based alert on unexpected child processes spawned by the FTP daemon	Critical
Secure Coding / Input Validation	SQLi returned all user records; reflected XSS executed arbitrary script; command injection appended shell output — Tasks 2.5, 2.6	Parameterized queries for all DB access; output encoding on all reflected fields; strict input allowlisting on the ping module	Web Application Firewall (WAF) rule set blocking common injection signatures	Apache access/error log monitoring for injection patterns (currently not possible — log source missing)	Critical
Account Management / RBAC	msfadmin session created an unauthorized account (testuser) and used it to log in — Task 3.3 incident	Enforce least-privilege sudo policy; remove ability for standard accounts to run adduser/useradd; rotate the msfadmin credential immediately	Require secondary approval/change-ticket for any new account creation	Alert on any adduser/useradd executed via sudo; alert on sudo sessions opened from local console by service-style accounts	Critical
Password Policy	Default/weak credentials found on FTP (user:user, service:service, postgres:postgres) and SSH (testuser:test123) — Tasks 2.7, 2.8	Enforce a strong password policy (min length/complexity) across all services; eliminate default and shared credentials	Account lockout / rate limiting after N failed attempts (fail2ban or equivalent)	sshd.log / vsftpd.log monitoring for repeated auth failures — already visible, currently Manual only	High
Logging & Monitoring	No Apache/DVWA access or error log is collected on the log box — confirmed absent, Task 3.2/3.4	Wire the Apache access and error logs into the centralized log box	None available until logging exists — this gap IS the risk	Once wired: alerting on injection-pattern strings and repeated failed DVWA logins	High
Multi-Factor Authentication	All tested remote access (SSH) and the DVWA admin login rely on password-only authentication — Tasks 2.4, 2.8	Deploy MFA for SSH and for the DVWA/portal admin login	IP allowlisting for administrative interfaces as an interim measure	Log and alert on repeated MFA failures	Medium-High
Network Segmentation / Firewall	Nmap enumeration found numerous exposed, non-essential services (RPC, NFS, Samba, VNC, Tomcat, IRC, PostgreSQL, MySQL) — Task 2.1, 2.2	Disable unused services; segment the customer-facing web server from internal/administrative services	Firewall rules restricting each service to only the hosts/ports that need it	Network-level scan/IDS detection for rapid multi-port connection attempts	Medium
Backup & Recovery	Not directly tested in this engagement — general hygiene recommendation	Implement regular, tested backups stored isolated from the production network	N/A	Automated backup-completion / failure alerting	Medium
User Awareness	Not directly tested in this engagement — general hygiene recommendation	Security awareness training covering phishing, credential hygiene, and reporting suspicious activity	N/A	Track training completion; phishing-simulation click-rates	Low-Medium

Task 4.2 — Executive Summary

Overall posture: SecureCorp's customer portal environment has multiple critical weaknesses that would allow an attacker to gain full control of the affected server, steal customer data, and maintain hidden, long-term access — all without being detected by current monitoring.

Most critical findings: An outdated file-transfer service contains a known backdoor that grants immediate, complete control of the server with no password required. Separately, the customer-facing web application does not properly check user

input, which let us extract every customer record from its database and run arbitrary commands on the server. During our investigation we also found evidence of a real, unauthorized intrusion — someone gained access, looked around, and created a hidden backdoor account for themselves — that was not part of our own testing.

Highest business risks: Customer data exposure (breach notification, legal, and reputational cost), complete loss of server control, and — most urgently — an active, unauthorized foothold that we found already present in the environment, which was not being detected by any existing monitoring.

Top recommendations: (1) Patch the backdoored file-transfer service immediately. (2) Fix the input-handling flaws in the web application. (3) Remove the unauthorized account we found and rotate the credential it used to gain access. (4) Turn on logging for the web application — it currently generates no record at all of who accesses it or how, which is the single biggest blind spot in the environment. (5) Add password and multi-factor requirements across remote access and admin logins.

Task 4.4 — Limitations

(Report Appendix A §10 — pulled directly from Task 3.4 detection-coverage notes)

- DVWA was tested only at security level "Low." Medium/High/Impossible levels apply input filtering and would likely block or complicate the SQLi, XSS, and command-injection payloads used here — those levels were not assessed.
- The Apache/DVWA access and error logs are not collected on the log box at all, so the entire web-attack surface (DVWA brute force, SQLi, XSS, command injection) is invisible to this engagement's detection review — confirmed absent, not merely unsearched (Task 3.2).
- The Nmap reconnaissance scan left no auth-log-level trace in the service logs reviewed; without network-level (IDS/flow) logging, this class of activity would go entirely undetected.
- Findings depend on the timestamps recorded during Week 2 attack execution; any activity performed without a recorded timestamp would have been indistinguishable from the seeded incident during Week 3 correlation.
- This engagement used the Core manual-investigation path only; no SIEM (Wazuh) was deployed, so no automated-detection comparison exists — all detection status in this report is "Manual."
- Numerous services identified by Nmap (RPC, NFS, Samba, VNC, Tomcat, IRC, PostgreSQL, MySQL) were catalogued but not further tested — only the FTP backdoor, SSH, and DVWA/HTTP surfaces were exploited in Week 2.
- An isolated lab cannot represent real user behavior, production scale/traffic volume, an EDR agent, or a tuned SIEM — findings on detectability may not transfer directly to a production environment.
- The lab's VMs initially ran on UTM's Shared Network mode rather than a fully isolated network; this was identified and corrected to Host Only mode before Week 2 attacks began, with connectivity re-verified afterward (see Week 1, Network Mode Correction).

SecureCorp Security Assessment

Final Client Debrief — Week 4

Junior Security Consultant Capstone | Target: 10.10.10.10 (isolated lab)

Overall Posture

SecureCorp's customer portal environment has multiple critical weaknesses that would allow an attacker to gain full control of the affected server, steal customer data, and maintain hidden, long-term access — all without being detected by current monitoring.

Highest business risks:

- Customer data exposure (breach, legal, reputational cost)
- Complete loss of server control
- An active, unauthorized foothold already present and undetected

Key Findings — Critical

vsftpd 2.3.4 Backdoor

CVSS 10.0

Known backdoor (CVE-2011-2523) gave immediate, unauthenticated root shell access to the server.

Web Application Input Flaws

CVSS 6.5–8.8

SQL injection exposed every customer record; command injection allowed arbitrary OS commands.

Unauthorized Intrusion Found

Confirmed Incident

A real, pre-existing backdoor account was discovered during our investigation — not part of our own testing.

The Unauthorized Intrusion

What we found:

An account (testuser) was created from the local console by msfadmin, then used to log in remotely — activity never part of our own testing.

How we told it apart from our own testing:

- Source: local console (TTY=tty1) vs. our documented remote tooling
- Action type: account creation — not part of any Week 2 task
- Timing: our own credential discovery for this account came after it already existed

Classification: INCIDENT — confirmed unauthorized access with an active, standing backdoor.

Top Recommendations

1. Patch the backdoored FTP service immediately
2. Fix input-handling flaws in the web application (parameterized queries, output encoding)
3. Remove the unauthorized account and rotate the compromised credential
4. Enable logging for the web application — currently the single biggest blind spot
5. Add MFA across remote access and admin logins

Lessons Learned

Attacker vs. defender knowledge gap:

As attacker, I knew exactly what, when, and how. As defender, I had to reconstruct all of it from raw logs alone.

The hardest attacks to detect weren't the cleverest ones:

They were undetectable simply because no log source existed for that layer — a structural gap, not a stealth technique.

Detection is about noticing what doesn't fit:

The real intrusion was found through one quiet field (TTY=tty1) that didn't match the expected pattern — not an obvious red flag.

Questions?

Thank you — SecureCorp Security Assessment Engagement

Reflection — SecureCorp Security Assessment Engagement

Task 4.4 | Junior Security Consultant (Student) | W4-T4.4-reflection

1. You attacked SecureCorp, then investigated it. What did the attacker know that the defender didn't?

As the attacker, I had perfect knowledge of my own actions: I knew my source IP (10.10.10.5), the exact service I was targeting, and the exact moment I ran each attack, because I was the one typing the commands. None of that was available to me once I switched to the defender's chair in Week 3.

As the defender, I started with nothing but a pile of raw logs and no prior context. I had to grep the logs for my own IP just to confirm an attack had even happened, read through timestamps to reconstruct a timeline, and cross-check everything against my own Week 2 attack notes to separate my testing from anything else. The attacker's advantage isn't skill — it's that they already know the answer to every question the defender has to go digging for.

2. Which of your attacks was hardest to detect, and why?

The DVWA-based attacks — SQL injection, reflected XSS, and OS command injection — were by far the hardest to detect. But the reason had nothing to do with how I executed them; I wasn't using any stealth technique or trying to evade detection. They were undetectable for a much simpler reason: no Apache/DVWA access or error log was ever being collected on the log box in the first place.

This was a structural blind spot, not a skill gap on my part as the attacker. I confirmed this directly in Task 3.2 — I checked every log file that existed on the log box, and the entire web layer simply wasn't represented anywhere. It's a useful lesson: the most dangerous attacks aren't always the cleverest ones, they're the ones that happen to land in a part of the system nobody is watching.

3. What did the seeded incident (Task 3.3) teach you that your own attacks didn't?

My own Week 2 attacks all came from one predictable place — 10.10.10.5, over the network, using known tools like Hydra and Metasploit. The seeded incident looked completely different, and that difference is what taught me the most.

The detail that gave it away was the TTY=tty1 field in sudo.log — it showed the session originated from the local console, not a remote login like every one of my own Week 2 activities. I had to notice that one field buried among routine log noise, then cross-check the timestamps against my own attack log to be sure it wasn't something I'd simply forgotten doing.

That process is the real lesson of this engagement: detection isn't about finding something obviously malicious — it's about noticing when something doesn't fit the pattern you'd expect, and having the discipline to verify it rather than assume. A real SOC analyst doesn't get a banner that says "this one's the intrusion." They get a field like TTY=tty1 sitting quietly in a log, and it's on them to notice it.

SecureCorp Security Assessment Engagement

Research Log

Prepared by: Junior Security Consultant (Student)

Note on this log: this record was reconstructed after the fact from what each weekly report already documented as a resolved blocker. For several entries, the specific research steps taken at the time (what was searched, which source helped) were not recorded as they happened, and are marked below as "Not recorded at the time" rather than invented. This is an honest gap in note-taking discipline during the engagement, not a gap in the troubleshooting itself — each issue below was in fact identified and resolved, with the fix confirmed in the corresponding weekly report.

Log

Week / Task	What Broke	What Fixed It	Source / Method	Notes
Week 1, Task 1.1	Target VM would not boot — UEFI/BIOS boot mode mismatch	Corrected the VM's boot firmware setting to match the OVA's expected mode	Not recorded at the time	Resolved; documented only as a resolved blocker in the Week 1 progress note
Week 1, Task 1.5	rsyslog on the log box was not receiving forwarded logs — AppArmor and directory-ownership issues	Adjusted AppArmor profile / directory permissions so rsyslog could write to the log path	Not recorded at the time	Resolved; documented only as a resolved blocker in the Week 1 progress note
Week 1, Task 1.5	Log forwarding config on the target had a syntax error, so logs never left the target	Corrected the syntax in the rsyslog forwarding config file	Not recorded at the time	Resolved; documented only as a resolved blocker in the Week 1 progress note
Week 2, Task 2.8	Hydra could not complete the SSH handshake against the target — key-exchange / MAC algorithm mismatch with the legacy OpenSSH version	Added KexAlgorithms, HostKeyAlgorithms, and MACs overrides to the attacker's SSH client config to support the legacy algorithms	Not recorded at the time	Confirmed fix — full error output and working config saved in the Week 2 evidence screenshot
Week 1 / Week 2 boundary	All three lab VMs (Kali, target, log box) were running on UTM's Shared Network mode instead of a properly isolated network, which doesn't fully meet the engagement's isolation requirement	Switched all three VMs' Network Mode from Shared Network to Host Only (Default private); re-verified all static IPs and inter-VM connectivity afterward with no reassignment needed	Identified and corrected collaboratively while reviewing the lab for this report; UTM's own Network settings panel was used to diagnose and change the mode	Confirmed fix — documented with before/after ping evidence in Week 1, "Network Mode Correction"

Reflection on Research Practice

Going forward, the habit this log makes clear is worth keeping: when a blocker is hit and resolved, write down the error, what was tried, and what worked, at the time — not after. Several of the fixes above were real and effective, but because the research trail wasn't captured in the moment, this log can only state the outcome, not the method, which is a weaker form of evidence than the handbook's own research-log guidance (Section 6) asks for.